



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

TAREA – SEMANA 3

DIAGNÓSTICO DE MADUREZ Y ANÁLISIS DEL MODELO CMMI 2.0

Autor (es):

Quezada Gallardo, Angelo Diancarlo – aquezadag1@miumg.edu.gt
Hernández Bámac, Keneth Vladimir – khernandezb6@miumg.edu.gt
Sosa Arroyo, Danny Josué – dsosaa1@miumg.edu.gt
Gil Rodríguez, Gerber David – ggilr1@miumg.edu.gt
Rodríguez Díaz, Carlos Alejandro – crodriguez10@miumg.edu.gt

Profesor

Ingeniera Mixtun López, Aura Denmi

Curso

Diseño de seguridad y CMMI – Segundo - 2026

Guatemala, 2026

ÍNDICE

INTRODUCCIÓN.....	4
1. INFORMACIÓN GENERAL DE LA ORGANIZACIÓN.....	6
Nombre de la organización.....	6
Giro del negocio.....	6
Sector.....	6
Tamaño de la organización.....	6
Dependencia tecnológica.....	6
Situación actual	7
Importancia de la seguridad en la organización.....	7
2. ANÁLISIS DEL MODELO CMMI 2.0 APLICADO	8
a. ¿Qué es CMMI y por qué es importante?	8
b. Estructura del modelo.....	9
c. Capacidad vs Madurez	10
d. Enfoque basado en procesos.....	11
3. ANÁLISIS POR CATEGORÍAS.....	12
a. Haciendo (Doing).....	12
¿Se ejecutan procesos definidos?	12
¿Existen actividades repetibles?	12
b. Administrando (Managing).....	13
¿Se planifica, monitorea y controla el trabajo?	13
¿Existen indicadores?	14
c. Habilitando (Enabling)	15
d. Mejorando (Improving).....	17
4. NIVEL DE MADUREZ ORGANIZACIONAL	20
Nivel 4: Cuantitativamente Gestionado	20
5. COMPARACIÓN CONCEPTUAL.....	21
Nivel 5: Optimización	21
6. ANÁLISIS DE SEGURIDAD	21
6.1. Riesgos de seguridad identificados	22
6.2. Impacto de la falta de procesos en la seguridad	23
6.3. Tipos de incidentes que podrían ocurrir	24
6.4. Controles de seguridad prioritarios a implementar	25

7. PROPUESTA INICIAL DE MEJORA.....	26
8. CONCLUSIÓN.....	29
REFERENCIAS	32

INTRODUCCIÓN

En un entorno empresarial cada vez más digitalizado y competitivo, la madurez de los procesos organizacionales se ha convertido en un factor determinante para la sostenibilidad, la eficiencia y, fundamentalmente, para la seguridad de la información. Las organizaciones que operan con procesos reactivos, informales o dependientes de individuos específicos no solo enfrentan ineficiencias operativas, sino que quedan expuestas a riesgos críticos que pueden comprometer su reputación, sus activos y la confianza de sus clientes. En este contexto, el modelo CMMI 2.0 (Capability Maturity Model Integration) se erige como una hoja de ruta estructurada y probada internacionalmente para evaluar, guiar y consolidar la evolución de las capacidades organizacionales, desde prácticas impredecibles hasta un enfoque de optimización continua.

El presente análisis aplica este marco teórico al caso concreto de Rápido Express Guatemala, S.A., una empresa de distribución y paquetería cuya operación depende críticamente de la disponibilidad, integridad y confidencialidad de sus sistemas digitales de rastreo, gestión de rutas y datos de clientes. A partir de un diagnóstico situacional que ubica a la organización en un Nivel 2 (Gestionado), este trabajo identifica las brechas fundamentales que separan a Rápido Express de un enfoque proactivo y estandarizado hacia la seguridad y la calidad. Se demuestra, a lo largo del análisis, que las debilidades en materia de ciberseguridad —como accesos no autorizados, falta de respuesta a incidentes o vulnerabilidad del personal ante ataques de ingeniería social— no son fallas aisladas, sino síntomas directos de un nivel de madurez organizacional todavía incipiente.

Sin embargo, alcanzar un nivel superior de madurez no es un fin en sí mismo; es el medio para construir una organización predecible, resiliente y capaz de aprender de sus propios errores. Por ello, este documento no solo diagnostica, sino que propone acciones concretas alineadas con las categorías de Habilitando (Enabling) y Mejorando (Improving) del modelo CMMI 2.0. A través de estas dos lentes analíticas, se responderán preguntas clave: ¿cuenta Rápido Express con las herramientas, la capacitación y el soporte organizacional necesarios para ejecutar sus procesos de seguridad de forma competente? ¿Existe una cultura de mejora continua que analice las fallas, extraiga aprendizajes y evite su recurrencia?

A partir de la integración de los marcos de CMMI, el análisis de riesgos de seguridad y una propuesta de mejora priorizada, esta introducción sienta las bases para demostrar que la seguridad de la información no es un añadido técnico, sino una consecuencia natural de la madurez organizacional. Para Rápido Express, el camino desde el Nivel 2 hacia el Nivel 3 y más allá no representa solo un avance en certificaciones, sino una transformación estratégica que le permitirá operar con control, confianza y capacidad de innovación en un mercado que no perdona la improvisación.

1. INFORMACIÓN GENERAL DE LA ORGANIZACIÓN

Nombre de la organización

Rápido Express Guatemala, S.A.

Giro del negocio

Rápido Express Guatemala, S.A. la cual se dedica a la distribución, logística y servicio de paquetería a nivel nacional, enfocada en la recepción, clasificación, transporte y entrega de paquetes y documentos para clientes individuales y corporativos, apoyándose en sistemas digitales para la gestión de rutas, rastreo de envíos y control operativo.

Sector

Rápidos Express Guatemala, S.A. pertenece al sector de logística y transporte, específicamente al área de servicios de mensajería y distribución.

Tamaño de la organización

Es considerada una empresa de tamaño mediano, con personal administrativo, operadores logísticos, pilotos, personal de atención al cliente y técnico de soporte, distribución en diferentes áreas operativas y centros de distribución.

Dependencia tecnológica

Depende significativamente de la tecnología para garantizar la continuidad de sus operaciones, entre los sistemas y recursos tecnológicos más importantes se encuentran:

- Plataforma de rastreo de paquetes en tiempo real.
- Sistemas de gestión de rutas y entregas.
- Bases de datos de clientes y envíos.
- Infraestructura de red y comunicación interna.
- Equipos móviles utilizados por pilotos y operadores.
- Servicios de correo electrónico y almacenamiento digital.

Situación actual

En la actualidad, Rápido Express presenta un nivel de madurez de Nivel 2 – Gestionado, según el modelo de CMMI institute CMMI 2.0 lo cual significa que algunos procesos ya son planificados y ejecutados de forma controlada, por lo que, aún existen debilidades relacionadas con la estandarización, documentación y mejora continua de los procesos de seguridad y operación.

Algunas problemáticas son:

- Falta de políticas formales de seguridad de la información.
- Controles de acceso limitados o inconsistentes.
- Escasa capacitación del personal en ciberseguridad.
- Ausencia de procedimientos estructurados de respuesta ante incidentes.
- Dependencia de conocimientos individuales para ejecutar tareas críticas.

Importancia de la seguridad en la organización

Rápido Express maneja información sensible relacionada con clientes, direcciones, rutas de transporte y estados de entrega, por lo que, de haber alguna interrupción, pérdida o

filtración de información podría afectar directamente la continuidad del negocio, generar pérdidas económicas y dañar la reputación de la empresa.

2. ANÁLISIS DEL MODELO CMMI 2.0 APLICADO

a. ¿Qué es CMMI y por qué es importante?

Es un marco de referencia internacional diseñado para ayudar a las organizaciones a mejorar sus procesos, aumentar la eficiencia operativa y fortalecer la calidad de sus servicios y productos, el propósito principal es guiar a las empresas hacia un nivel de madurez organizacional más alto mediante prácticas estructuradas y orientadas a la mejora continua.

Es importante la implementación del CMMI en Rápido Express Guatemala, S.A. ya que radica en que la empresa depende considerablemente de sistemas tecnológicos y procesos logísticos que deben funcionar de forma segura, estable y controlada, en la actualidad, la organización presenta varias debilidades relacionadas con la gestión de procesos y seguridad de la información, por lo que la adopción de CMMI permitiría establecer estándares claros de trabajo y mejorar la administración operativa.

Algunos problemas que CMMI podría ayudar a resolver se encuentran:

- Falta de documentación y estandarización de procesos.
- Dependencia excesiva de conocimientos individuales.
- Ausencia de procedimientos formales de seguridad.
- Respuesta deficiente ante incidentes tecnológicos.
- Escasa capacitación del personal en temas de ciberseguridad.

- Dificultad para medir el desempeño y detectar fallas operativas.

b. Estructura del modelo

CMMI 2.0 es compuesto por diferentes elementos que permiten evaluar y mejorar la madurez organizacional de manera estructurada, este modelo integra prácticas, dominios de capacidad, niveles de madurez y áreas de desempeño enfocadas en mejorar la gestión empresarial y tecnológica.

Views (vistas) aplicables

Las vistas aplicables son:

- Development (DEV): aplicable al desarrollo y mantenimiento de sistemas internos de rastreo y control logístico.
- Services (SVC): relacionada con la prestación de servicios logísticos y atención al cliente.
- Security (SEC): enfocada en la protección de la información, gestión de riesgos y fortalecimiento de controles de seguridad.

Componentes del modelo

Los principales componentes del CMMI 2.0 que se muestran en el análisis organizacional son:

- Niveles de madurez: utilizados para medir el grado de evolución de los procesos organizacionales.
- Áreas de práctica: orientadas a la gestión de proyectos, soporte, seguridad y mejora continua.

- Prácticas específicas y genéricas: utilizadas para establecer actividades controladas y repetibles.
- Evaluación del desempeño: enfocada en medir resultados y detectar oportunidades de mejora.

Contexto de uso

El modelo ayuda a:

- Evaluar el estado actual de los procesos.
- Identificar riesgos relacionados con la seguridad de la información.
- Proponer mejoras organizacionales.
- Establecer controles y procedimientos formales.
- Fortalecer la continuidad operativa y la calidad del servicio.

c. Capacidad vs Madurez

Los conceptos de capacidad y madurez tienen cierta similitud, pero poseen diferencias importantes.

En el caso de la capacidad, este se refiere al desempeño de un proceso específico dentro de la organización, el cual evalúa qué tan bien una actividad o área concreta logra cumplir sus objetivos de manera consistentes y controlada.

Del lado de la madurez, este representa el nivel general de desarrollo de toda la organización respecto a la gestión de sus procesos, teniendo medidas integrales que reflejan qué tan estructurada, predecible y optimizada es la empresa.

Rápido Express Guatemala, S.A. se encarga de mostrar cierto nivel de capacidad, por ejemplo:

- Gestión básica de entregas y rastreo.
- Control operativo de rutas.
- Atención al cliente mediante plataformas digitales.

Aunque la madurez organizacional es algo limitada porque muchos procesos dependen de prácticas informales, experiencia individual y poca documentación.

d. Enfoque basado en procesos

Rápido Express Guatemala, S.A. trabaja con procesos parcialmente definidos, algunas actividades operativas y tecnológicas cuentan con lineamientos básicos, no obstante, gran parte de los procedimientos aún se ejecutan de manera informal o dependen de la experiencia del personal.

La falta de procesos completamente documentados y estandarizados genera diversos impactos negativos en el desempeño organizacional, algunos de estos son:

- Inconsistencias en la ejecución de tareas.
- Mayor probabilidad de errores operativos.
- Dificultad para capacitar nuevo personal.
- Problemas para responder rápidamente ante incidentes.
- Falta de trazabilidad y control.
- Incremento del riesgo de fallos de seguridad.

3. ANÁLISIS POR CATEGORÍAS

a. Haciendo (Doing)

¿Se ejecutan procesos definidos?

Teniendo en cuenta que la empresa Rápido Express trata de una organización de logística y envíos, se asegura que existen procesos operativos básicos, tales como:

- Recepción de pedidos
- Clasificación de paquetes
- Asignación de rutas de entrega
- Distribución y entrega al cliente

No obstante, existe la posibilidad de que:

- Los procesos no estén completamente documentados
- Dependan mucho de la experiencia del personal
- No exista una estandarización formal (Manuales o procedimientos escritos)

Como el análisis indica, Rápido Express ejecuta procesos, pero estos pueden ser informales o parcialmente definidos, lo que muestra un nivel de madurez bajo a intermedio en esta área.

¿Existen actividades repetibles?

Algunas actividades operativas que se repiten son:

- Registro de envíos en el sistema
- Preparación de paquetes
- Entregas diarias en rutas similares
- Confirmación de recepción

Lo que indica que:

- Sí hay repetibilidad en las operaciones
- No puede estar controlada por métricas o estándares formales

Se toman en cuenta las actividades repetidas, lo cual es positivo, pero probablemente:

- No están optimizadas
- No se miden como en KPIs como tiempo de entrega, errores u otros
- No siguen un proceso formalmente gestionado

b. Administrando (Managing)

¿Se planifica, monitorea y controla el trabajo?

Se asume que en Rápido Express existe cierto nivel de planificación operativa, la cual hace:

- Planificación diaria de rutas de entrega
- Asignación de repartidores
- Organización de horarios
- Priorización de envíos urgentes

No obstante, existe la posibilidad de que:

- La planificación sea reactiva, no estratégica
- El monitoreo se haga de forma básica
- No existan herramientas formales de control

Rápido Express da seguridad que planifica y monitorea, pero de manera limitada y poco formalizada, lo que indica una gestión operativa más que una gestión basada en procesos maduros.

¿Existen indicadores?

En Rápido Express existen algunos como:

- Tiempo promedio de entrega
- Número de entregas diarias
- Paquetes retrasados o fallidos

Pero es probable que:

- No estén documentados como KPIs formales
- No se analicen periódicamente
- No se utilicen para toma de decisiones estratégicas
- No haya herramientas automatizadas para su seguimiento

Teniendo en cuenta que los indicadores básicos son detectados, existe la necesidad de un sistema estructurado de medición y control de desempeño.

c. **Habilitando (Enabling)**

Pregunta guía: ¿Existen herramientas, capacitación o soporte organizacional para ejecutar los procesos de manera competente y con los recursos adecuados?

Aspecto	Situación en Rápido Express (Nivel 2)	Brecha identificada	Acción propuesta para avanzar a Nivel 3	Beneficio esperado
Capacitación y Habilidades	El personal (operadores, repartidores, atención al cliente) no recibe formación sistemática en ciberseguridad. Son susceptibles a phishing e ingeniería social.	Falta de un programa formal y continuo de concienciación. La seguridad depende del conocimiento individual, no de una capacidad organizacional.	Desarrollar e implementar un plan de concienciación en ciberseguridad para toda la organización, con contenidos actualizados periódicamente.	Reducción de incidentes por error humano; cultura de seguridad; personal preparado para identificar y reportar amenazas.
Herramientas y Recursos	No se mencionan herramientas formales de gestión. Se depende de	Inexistencia de herramientas para centralizar logs,	Implementar monitoreo y registro de eventos (SIEM básico). Establecer un	Visibilidad centralizada de la infraestructura; capacidad de detectar

procesos locales sin soporte tecnológico centralizado.	monitorear eventos o gestionar vulnerabilidades de forma automatizada.	inventario de activos y herramientas de escaneo de vulnerabilidades.	comportamientos anómalos; base para métricas de seguridad.
Ausencia de herramientas de monitoreo (SIEM).			

Los procesos de seguridad

no están estandarizados.	Falta de un marco de políticas oficial respaldado por la gerencia y aplicable a toda la empresa. No hay dueños de proceso definidos.	Implementar gestión formal de identidades y accesos (IAM). Documentar políticas de control de privilegios, MFA y revisión periódica de cuentas.	Trazabilidad de acciones por usuario; reducción de accesos indebidos; cumplimiento de estándares de seguridad de la información.
Cada área aplica sus propias prácticas (ej: un área usa contraseñas fuertes, otra comparte credenciales). No hay políticas formales de acceso.			

Soporte
Organizacional

d. Mejorando (Improving)

Preguntas guía: ¿Se realizan mejoras continuas? ¿Se analizan errores o fallas para eliminar sus causas raíz y evitar recurrencias?

		Acción propuesta para		
	Situación en		avanzar a Nivel 3 (o superior)	Beneficio esperado /
Aspecto	RápidoExpress (Nivel 2)	Brecha identificada		Relación con Niveles 4-5
		Ausencia de		Pasar de ser reactivo a
	No se menciona ningún	un procedimiento	Establecer un proceso	proactivo. Evitar que un
	proceso de análisis de fallas.	documentado para	formal de gestión de	mismo tipo de incidente se
	Los incidentes de seguridad	investigar desviaciones,	incidentes de seguridad que	repita en el futuro. Base
	se atienden de forma	errores o incidentes,	incluya una fase de análisis	para avanzar al Nivel
Análisis de	reactiva e improvisada, sin	identificar su causa raíz y	post-incidente (lecciones	4 (control estadístico de
Causa Raíz	registro formal ni	definir acciones correctivas	aprendidas y análisis de	incidentes) y Nivel 5 (cero
(CAR)	aprendizaje posterior.	permanentes.	causa raíz).	defectos estructurales en
				seguridad).

				Disminución continua de
	No existe un ciclo de mejora formal. Los procesos de seguridad, cuando existen, son estáticos y varían por área. No se miden ni se ajustan con base en resultados.	Falta de una retroalimentación sistemática desde la operación y los incidentes hacia la mejora de los procesos estandarizados.	Integrar la gestión de vulnerabilidades y parches como un ciclo PDCA (Planificar-Hacer-Verificar-Actuar): escanear, priorizar, parchear, verificar y ajustar el proceso.	la exposición a vulnerabilidades conocidas. Mayor estabilidad de los sistemas. Alineación con buenas prácticas (CIS Controls).
Mejora Continua de Procesos		Para llegar al Nivel 5 (Optimización), se	*Acción a futuro (post-Nivel 3):* Establecer un	Convertir la seguridad en
	La organización no tiene capacidad de mejorar más allá de corregir lo urgente.	necesitaría un proceso formal de innovación que evalúe nuevas tecnologías	comité de mejora que revise periódicamente las métricas de seguridad (ej: tiempo de respuesta a incidentes, número de accesos	una ventaja competitiva. Capacidad de adaptarse a nuevas amenazas sin perder estabilidad.
Innovación y Optimización	No hay visión de optimización proactiva.	(ej: IA para detectar vulnerabilidades) y las		Objetivo de "cero

integre si mejoran los
objetivos de negocio.

indebidos bloqueados) y
proponga innovaciones.

defectos" en controles
críticos.

4. NIVEL DE MADUREZ ORGANIZACIONAL

Nivel 4: Cuantitativamente Gestionado

En este nivel, la organización utiliza datos estadísticos para predecir el rendimiento de los procesos. Ya no basta con decir que un proceso "funciona"; se debe demostrar con números exactos su variabilidad y capacidad.

- **Enfoque Principal:** Predicción y Control Estadístico.
- **Características en la Organización:**
 - **Subprocesos Críticos:** La empresa identifica qué partes del desarrollo son críticas (por ejemplo, la etapa de pruebas de seguridad o el tiempo de respuesta de la base de datos) y aplica control estadístico sobre ellas.
 - **Líneas Base de Rendimiento (PBL):** Se establecen rangos numéricos de éxito. Por ejemplo: "El proceso de codificación debe generar menos de 0.5 errores por cada mil líneas de código".
 - **Gestión de Riesgos Cuantitativos:** Los riesgos de seguridad no solo se identifican, sino que se calcula su probabilidad de ocurrencia e impacto financiero exacto mediante modelos matemáticos.
- **Justificación de este Nivel:** La organización logra que sus resultados sean predecibles. Si se inicia un proyecto, la gerencia sabe, con un margen de error mínimo, cuántos recursos se gastarán y cuántos defectos se encontrarán antes de la entrega.

5. COMPARACIÓN CONCEPTUAL

Nivel 5: Optimización

Este es el nivel máximo de madurez, donde la organización se enfoca en la **mejora continua e innovación tecnológica** de manera disciplinada y sistemática.

- **Enfoque Principal:** Innovación y Mejora del Rendimiento.
- **Características en la Organización:**
 - **Análisis de Causa Raíz (CAR):** Ante cualquier desviación mínima en la calidad o seguridad, se realiza un análisis profundo para eliminar la causa de raíz y evitar que vuelva a ocurrir en cualquier otro proyecto.
 - **Gestión de la Innovación:** La empresa tiene un proceso formal para evaluar nuevas tecnologías (como IA para detección de vulnerabilidades) y decidir si su implementación mejorará los objetivos de negocio.
 - **Cero Defectos:** El objetivo no es solo corregir errores, sino optimizar los procesos para que los errores dejen de producirse estructuralmente.
- **Justificación de este Nivel:** La organización es ágil y capaz de responder a cambios drásticos en el mercado o en las amenazas de ciberseguridad sin perder estabilidad ni calidad. Los procesos se ajustan dinámicamente según el rendimiento histórico.

6. ANÁLISIS DE SEGURIDAD

El análisis de seguridad que se presenta a continuación toma como punto de partida el nivel de madurez 2 (Gestionado) identificado por el equipo para Rápido Express Guatemala,

S.A. En este nivel, la organización ha logrado que algunas prácticas sean repetibles y planificadas localmente, pero aún carece de procesos estandarizados en toda la empresa, de métricas consolidadas de seguridad y de una cultura organizacional orientada a la prevención de riesgos. Esta situación crea una brecha significativa entre la operatividad del negocio y la protección de sus activos de información.

6.1.Riesgos de seguridad identificados

Dado el nivel de madurez actual, los riesgos de seguridad más relevantes para la organización son los siguientes:

- Acceso no autorizado a sistemas internos: La ausencia de una política formal de gestión de identidades y accesos (IAM) significa que empleados con roles distintos pueden acceder a información que no les corresponde. En empresas de distribución, esto afecta directamente los datos de rastreo de paquetes, rutas y clientes.
- Exposición de datos de clientes: Rápido Express maneja volúmenes elevados de información personal (nombres, direcciones, teléfonos, contenido de envíos). Sin controles de protección de datos, esta información es vulnerable a fugas, ya sea por error humano o por ataque dirigido.
- Dependencia del factor humano sin formación adecuada: Los operadores de bodega, repartidores y personal de atención al cliente interactúan constantemente con sistemas digitales. Sin capacitación en ciberseguridad, son susceptibles a ataques de ingeniería social y phishing.

- Falta de visibilidad sobre la infraestructura tecnológica: Sin un inventario de activos formalizado ni herramientas de monitoreo, la organización no tiene claridad sobre qué sistemas están expuestos, desactualizados o mal configurados.
- Riesgos en la cadena logística: Los sistemas de rastreo y los dispositivos móviles de los repartidores representan puntos de entrada potenciales para actores maliciosos, especialmente si se conectan a redes no seguras.

6.2. Impacto de la falta de procesos en la seguridad

La relación entre madurez organizacional y seguridad es directa y bidireccional. Una organización que opera en el Nivel 2 de CMMI posee procesos planificados, pero no estandarizados, lo que genera los siguientes impactos en materia de seguridad:

- Inconsistencia en la aplicación de controles: Si cada área aplica sus propias prácticas de seguridad de forma independiente, el nivel de protección varía y se crean brechas explotables. Un área puede tener contraseñas fuertes mientras otra usa credenciales compartidas.
- Respuesta reactiva ante incidentes: Sin procesos definidos de respuesta a incidentes, la organización actúa de forma improvisada cuando ocurre un evento de seguridad, prolongando el tiempo de contención y aumentando el daño.
- Imposibilidad de auditar y cumplir regulaciones: Guatemala cuenta con normativas emergentes en protección de datos. Sin registros ni trazabilidad de acciones, la organización no puede demostrar cumplimiento ante una auditoría.

- Pérdida de confianza del cliente: Las empresas de mensajería y paquetería operan sobre la base de la confianza. Un incidente de seguridad que exponga información de envíos o clientes puede generar pérdidas irreversibles de reputación.

6.3. Tipos de incidentes que podrían ocurrir

Considerando el perfil de la organización y su nivel de madurez, los incidentes más probables son:

- Phishing dirigido a colaboradores: Correos fraudulentos que suplantando al área de TI o a proveedores logísticos para obtener credenciales de acceso a los sistemas de gestión de envíos.
- Robo o pérdida de dispositivos móviles: Los dispositivos utilizados por repartidores para confirmar entregas pueden contener datos de clientes. Sin cifrado ni gestión remota, un dispositivo perdido representa una fuga de información.
- Acceso no autorizado interno (insider threat): Un empleado con acceso a múltiples sistemas podría consultar, copiar o alterar información de envíos de competidores o clientes específicos, aprovechando la falta de controles de privilegio mínimo.
- Interrupción del sistema de rastreo: Un ataque de ransomware o una falla provocada por software desactualizado podría paralizar el sistema de seguimiento de paquetes, afectando directamente la operación y la promesa de servicio al cliente.
- Manipulación de datos de entrega: Sin integridad verificable en los registros, un colaborador podría alterar datos de confirmación de entrega para encubrir pérdidas o robos de paquetes.

6.4. Controles de seguridad prioritarios a implementar

Con base en los riesgos identificados y el nivel de madurez actual, se propone la siguiente priorización de controles de seguridad:

<i>Control prioritario</i>	<i>Descripción</i>	<i>Relación con madurez CMMI</i>
<i>Gestión de accesos e identidades (IAM)</i>	Control de privilegios, MFA, revisión periódica de cuentas activas y bajas.	Nivel 2 requiere procesos gestionados; sin control de accesos no se puede garantizar quién ejecuta qué proceso.
<i>Procedimiento de respuesta a incidentes</i>	Proceso documentado para detectar, contener, erradicar y recuperar ante incidentes de seguridad.	Refleja la categoría 'Haciendo': si no hay procesos definidos de respuesta, la organización opera de forma reactiva e impredecible.
<i>Gestión de vulnerabilidades y parches</i>	Inventario de activos, escaneo periódico de vulnerabilidades y ciclo de aplicación de parches críticos.	Avanzar hacia Nivel 3 exige procesos estandarizados; la gestión de parches es una práctica base que evidencia control sobre los activos.
<i>Monitoreo y registro de eventos (SIEM básico)</i>	Centralización de logs de sistemas críticos y alertas ante comportamientos anómalos.	La categoría 'Administrando' implica medir y monitorear; sin logs no hay visibilidad ni indicadores de seguridad.

Concienciación en seguridad	Programa de capacitación continua al personal sobre phishing, manejo de datos y políticas internas.	Categoría 'Habilitando': las personas son el activo más crítico; sin formación no hay soporte organizacional real para la seguridad.
------------------------------------	---	--

La implementación de estos controles no solo reduce el riesgo inmediato, sino que también eleva el nivel de madurez de la organización al institucionalizar procesos repetibles y medibles, condición necesaria para avanzar hacia el Nivel 3 de CMMI 2.0.

7. PROPUESTA INICIAL DE MEJORA

A partir del diagnóstico de madurez y el análisis de seguridad realizados, se proponen las siguientes acciones concretas orientadas a elevar el nivel organizacional de Rápido Express Guatemala, S.A. desde el Nivel 2 hacia el Nivel 3 del modelo CMMI 2.0, fortaleciendo simultáneamente su postura de seguridad de la información.

<i>Acción</i>	<i>Área impactada</i>	<i>Justificación</i>	<i>Beneficio esperado</i>
1. Implementar gestión formal de identidades y accesos (IAM)	TI / Seguridad	Los colaboradores acceden a sistemas críticos sin controles de privilegio mínimo ni	Reducción del riesgo de accesos indebidos, trazabilidad de acciones por usuario, y

		revisiones periódicas de cuentas activas. Esto representa un riesgo de acceso no autorizado ante rotación de personal.	cumplimiento con estándares de seguridad de la información.
2. Establecer un proceso formal de gestión de incidentes de seguridad	Operaciones / TI	No existe un procedimiento documentado para la detección, notificación y respuesta ante incidentes. Los eventos de seguridad se atienden de forma reactiva y sin registro formal.	Mayor velocidad de respuesta ante incidentes, reducción del impacto operativo, y generación de evidencia para análisis forense y mejora continua.
3. Implementar política de gestión de vulnerabilidades y parches	TI / Infraestructura	No hay un ciclo de actualización periódico ni un inventario de vulnerabilidades conocidas en los sistemas. El software desactualizado amplía la superficie de ataque.	Disminución de la exposición ante vulnerabilidades conocidas (CVEs), mayor estabilidad de los sistemas y alineación con buenas prácticas como CIS Controls.

4. Desarrollar y capacitar en un plan de concienciación en ciberseguridad	Toda la	El personal no recibe	Reducción de incidentes
	organización	formación sistemática	causados por error
		sobre amenazas como	humano, cultura
		phishing, ingeniería social	organizacional orientada a
		o manejo seguro de	la seguridad, y personal
		información. El factor	preparado para identificar
		humano es el vector de	y reportar amenazas.
		ataque más frecuente.	

Es importante destacar que estas cuatro acciones son complementarias y deben implementarse de forma progresiva. La gestión de identidades y accesos constituye la base, ya que sin saber quién hace qué en los sistemas, las demás mejoras tienen un alcance limitado. La gestión de incidentes permite aprender de los eventos y retroalimentar el resto de los procesos. La gestión de vulnerabilidades protege la infraestructura técnica, y la concienciación cierra el ciclo al fortalecer el eslabón humano.

Desde la perspectiva de CMMI 2.0, estas acciones representan el paso de procesos gestionados localmente (Nivel 2) a procesos estandarizados y documentados que pueden replicarse en toda la organización (Nivel 3). Al establecer políticas formales, métricas de seguimiento y capacitación sistemática, Rápido Express sienta las bases para una mejora continua sostenible.

8. CONCLUSIÓN

La importancia de CMMI en la gestión organizacional: El modelo CMMI 2.0 no es simplemente un marco de evaluación; es una hoja de ruta para la transformación organizacional. En el caso de Rápido Express Guatemala, S.A., una empresa de distribución de paquetes que opera en un entorno competitivo y con alta dependencia operativa de sus sistemas tecnológicos, la adopción del modelo representa la diferencia entre una organización que reacciona a los problemas y una que los anticipa y gestiona de forma sistemática.

La importancia de CMMI radica en que provee un lenguaje común para evaluar y mejorar los procesos, independientemente del sector o tamaño de la organización. Al estructurar las prácticas en torno a las cuatro categorías —Haciendo, Administrando, Habilitando y Mejorando— el modelo permite identificar con precisión dónde están las brechas y qué acciones concretas generarán el mayor impacto. Para Rápido Express, esto significa poder priorizar inversiones en procesos que hoy funcionan de forma reactiva y convertirlos en capacidades organizacionales predecibles y medibles.

El análisis realizado evidenció que la organización se encuentra en el Nivel 2, lo cual es un punto de partida válido. Muchas empresas guatemaltecas del sector logístico ni siquiera han formalizado sus procesos básicos. Sin embargo, mantenerse en este nivel en un entorno donde la digitalización avanza aceleradamente representa un riesgo estratégico. La competencia, los clientes y las regulaciones exigen cada vez más madurez operativa, y CMMI 2.0 ofrece el camino estructurado para alcanzarla.

La relación entre procesos, madurez y seguridad: Uno de los aprendizajes más relevantes de este análisis es la estrecha relación que existe entre el nivel de madurez de los procesos y la

postura de seguridad de la información de una organización. Esta relación no es accidental: la seguridad efectiva depende de procesos bien definidos, ejecutados de forma consistente y sujetos a mejora continua.

Una organización con procesos informales y dependientes de individuos específicos — característica del Nivel 1 de CMMI— es fundamentalmente insegura, no porque sus intenciones sean malas, sino porque la seguridad no puede sostenerse sobre bases ad hoc. Cuando los controles de acceso dependen de la memoria de una persona, cuando la respuesta a incidentes se improvisa en el momento o cuando no existe documentación de quién tiene acceso a qué sistema, cualquier cambio en el personal o cualquier evento inesperado puede comprometer la integridad, confidencialidad y disponibilidad de la información.

Rápido Express, en su Nivel 2, ha avanzado hacia una mayor previsibilidad, pero aún enfrenta riesgos significativos: procesos de seguridad que varían entre áreas, falta de indicadores que permitan detectar amenazas a tiempo y ausencia de un programa formal de capacitación. El avance hacia el Nivel 3, impulsado por las acciones propuestas, no solo mejorará la eficiencia operativa, sino que también fortalecerá de manera tangible la seguridad de la información, convirtiendo los controles de seguridad en prácticas institucionales y no en esfuerzos individuales aislados.

La seguridad, en definitiva, es una consecuencia de la madurez organizacional. No se puede tener una sin la otra de forma sostenida.

Principales aprendizajes obtenidos: El desarrollo de esta tarea permitió consolidar varios aprendizajes fundamentales sobre el modelo CMMI 2.0 y su aplicación práctica:

- CMMI 2.0 es un modelo vivo y aplicable: Su estructura modular y sus vistas configurables lo hacen aplicable a organizaciones muy diversas, desde startups tecnológicas hasta empresas de distribución física como Rápido Express. No requiere una implementación total desde el inicio; puede adoptarse de forma incremental.
- La madurez organizacional tiene consecuencias directas en la seguridad: Este análisis demostró que evaluar los procesos de una organización bajo el lente de CMMI automáticamente revela vulnerabilidades de seguridad. Las brechas en las categorías de Haciendo y Administrando se traducen directamente en controles de seguridad ausentes o inconsistentes.
- Las mejoras deben ser sistemáticas y priorizadas: No es posible resolver todas las brechas simultáneamente. El enfoque propuesto —comenzar por IAM, luego gestión de incidentes, luego vulnerabilidades y finalmente concienciación— refleja una lógica de construcción progresiva donde cada mejora habilita la siguiente.
- La seguridad es una responsabilidad organizacional, no solo técnica: Los controles técnicos son necesarios, pero insuficientes sin el respaldo de políticas, capacitación y liderazgo comprometido. CMMI 2.0, al incluir la categoría Habilitando, reconoce explícitamente que las personas y la cultura son componentes críticos de la madurez.
- El contexto guatemalteco exige adaptación del modelo: Las empresas de distribución en Guatemala operan con restricciones de presupuesto y talento humano especializado. La propuesta de mejora presentada considera esta realidad, ofreciendo acciones concretas y alcanzables que no requieren transformaciones radicales inmediatas, sino una evolución planificada y sostenible.

En síntesis, CMMI 2.0 ofrece a organizaciones como Rápido Express una oportunidad real de transformación. La madurez de los procesos no es un lujo reservado para grandes corporaciones; es una necesidad estratégica para cualquier organización que aspire a operar con eficiencia, confiabilidad y seguridad en el entorno digital actual. El camino hacia el Nivel 3 es exigente, pero los beneficios —operativos, competitivos y de seguridad— justifican plenamente el esfuerzo.

REFERENCIAS

CMMI Institute. (2018). *CMMI model, version 2.0*.

ISACA. (2019). *CMMI 2.0 at a glance. ISACA Journal*.

National Institute of Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity* (Version 1.1).

Center for Internet Security. (2021). *CIS controls v8*.

CMMI Institute. (2018). *CMMI model, version 2.0*. CMMI Institute.

ISACA. (2019). *CMMI 2.0 at a glance. ISACA Journal*.

National Institute of Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity* (Version 1.1). U.S. Department of Commerce.

Center for Internet Security. (2021). *CIS controls v8*. CIS.

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO.

Project Management Institute. (2021). *A guide to the project management body of knowledge (PMBOK® guide)* (7th ed.). PMI.

AXELOS. (2019). *ITIL foundation: ITIL 4 edition*. TSO.

OWASP Foundation. (2021). *OWASP top 10: The ten most critical web application security risks*. OWASP Foundation.

IEEE. (2021). *IEEE standard for system and software verification and validation*. IEEE.

International Organization for Standardization. (2018). *ISO 31000:2018 risk management guidelines*. ISO.

Information Systems Audit and Control Association. (2018). *COBIT 2019 framework: Introduction and methodology*. ISACA.